OWASP DEPENDENCY-TRACK

Community Meeting
November 2026

Organizational

- Community meetings are recorded and uploaded to YouTube
- Slides will be published in the DependencyTrack/community repository
- Please use the Zoom chat to ask questions during the presentation
- There will be an open Q&A section towards the end

Agenda

1. Recent releases
2. Telemetry insights
3. Noteworthy changes
4. Upcoming 5.3 release
5. Q&A

Recent releases

Recent releases

Much has happened since the last community meeting!

- 2026-08-27: **5.1.0** - *KEV, CycloneDX 1.7, JVN, …*
- 2026-09-12: **4.14.4** - *CycloneDX 1.7, Bugfixes…*
- 2026-09-20: **5.1.1** - *Bugfixes…*
- 2026-10-05: **4.14.5** - *Bugfixes…*
- 2026-10-06: **5.1.2** - *Bugfixes…*
- 2026-10-08: **5.2.0** - *Service accounts, Workload Identity Federation, …*
- 2026-10-25: **4.14.6** - *eMudhra distrust, Bugfixes…*
- 2026-10-25: **5.2.1** - *eMudhra distrust, Bugfixes…*

No fixed release schedule, but trying to ship regularly nonetheless.

v4 End Of Life

- Version 4 reaches end of life December 2026, ⚠️ **next month** ⚠️
- After that, no more bugfixes or security patches
- Please follow the migration guidance to move to v5

https://github.com/DependencyTrack/dependency-track/blob/5.2.1/V5_MIGRATION.md

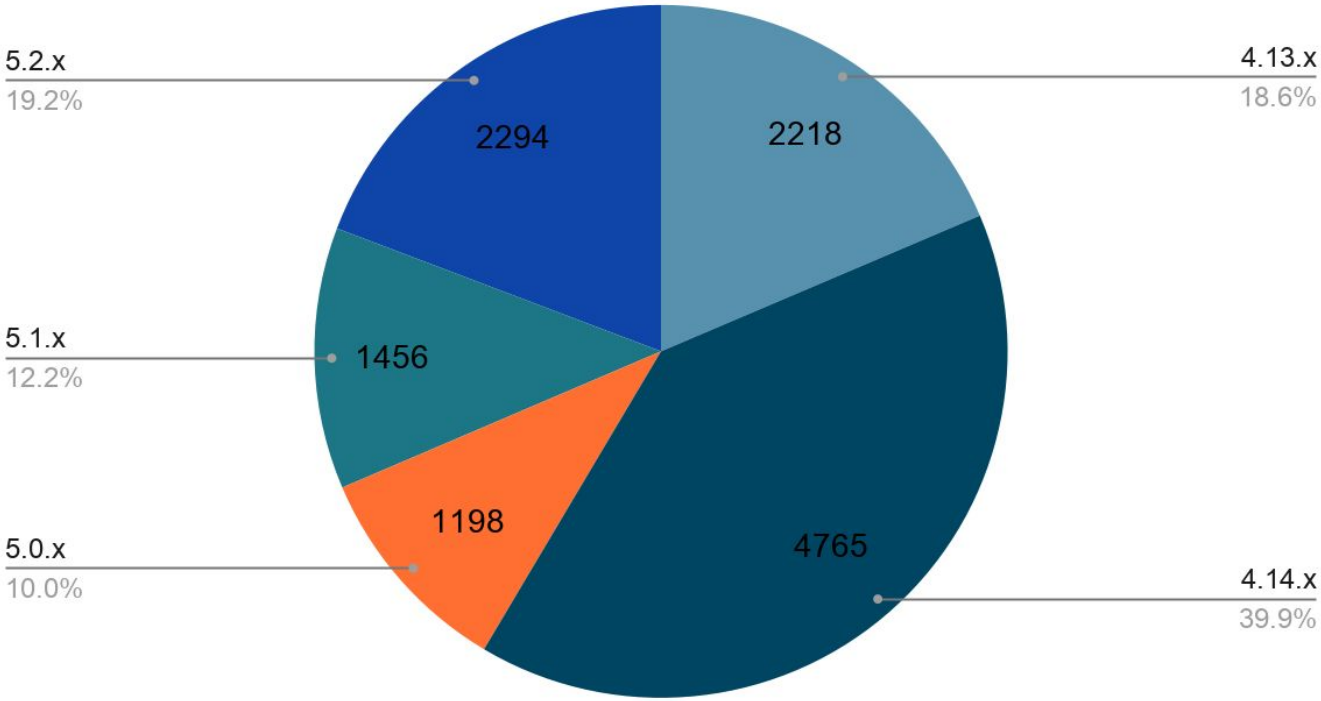
https://dependencytrack.github.io/docs/next/guides/administration/migrating-from-v4/

eMudhra Intermediate CA Compromise

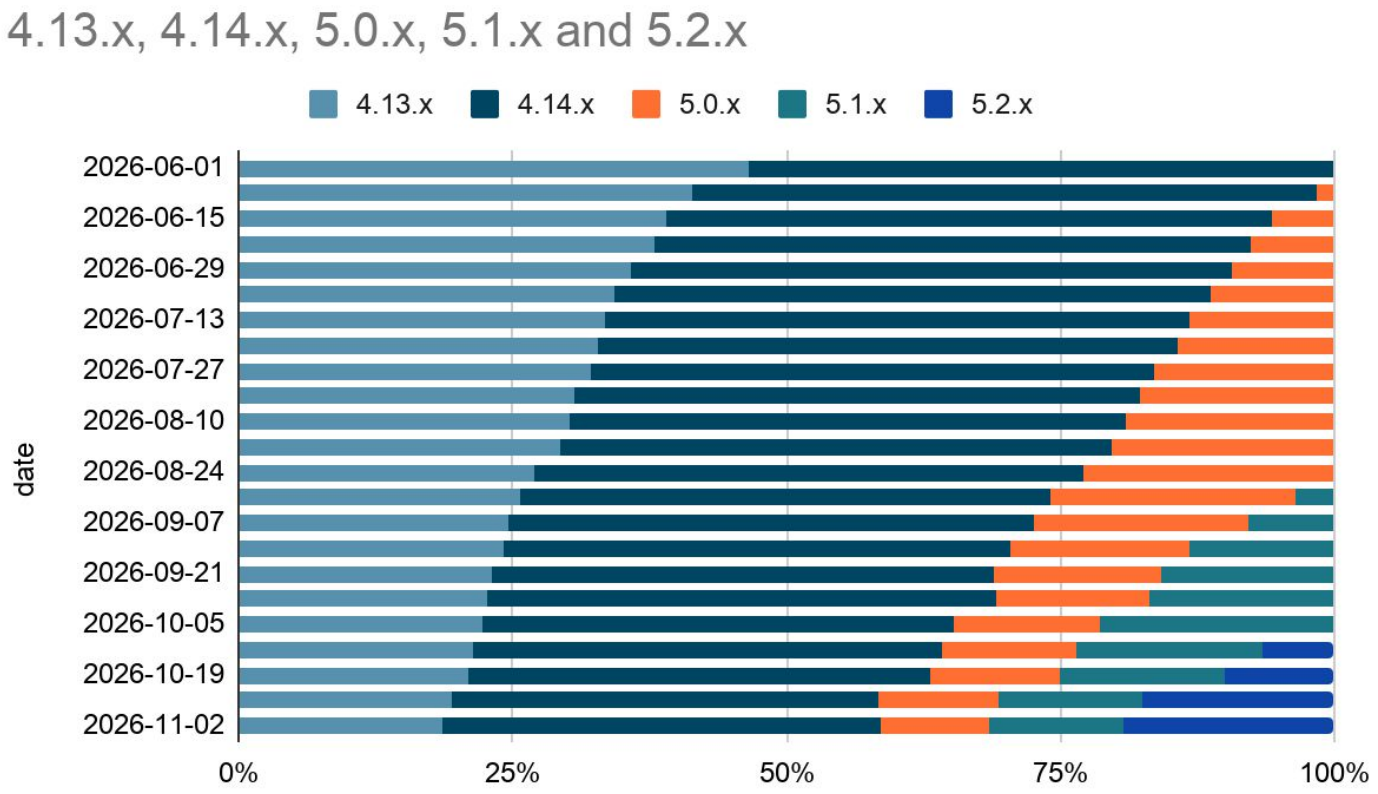
- https://emudhra.we-have-a-problem.com/
- Container deployers: upgrade to 5.2.1 or 4.14.6
- Bare metal deployers: upgrade your JDK to 25.0.5+ (check vendor advice)
- If you can’t upgrade, workarounds are available: https://github.com/DependencyTrack/dependency-track/discussions/7732

Telemetry insights

Version Distribution (02.11.2026)



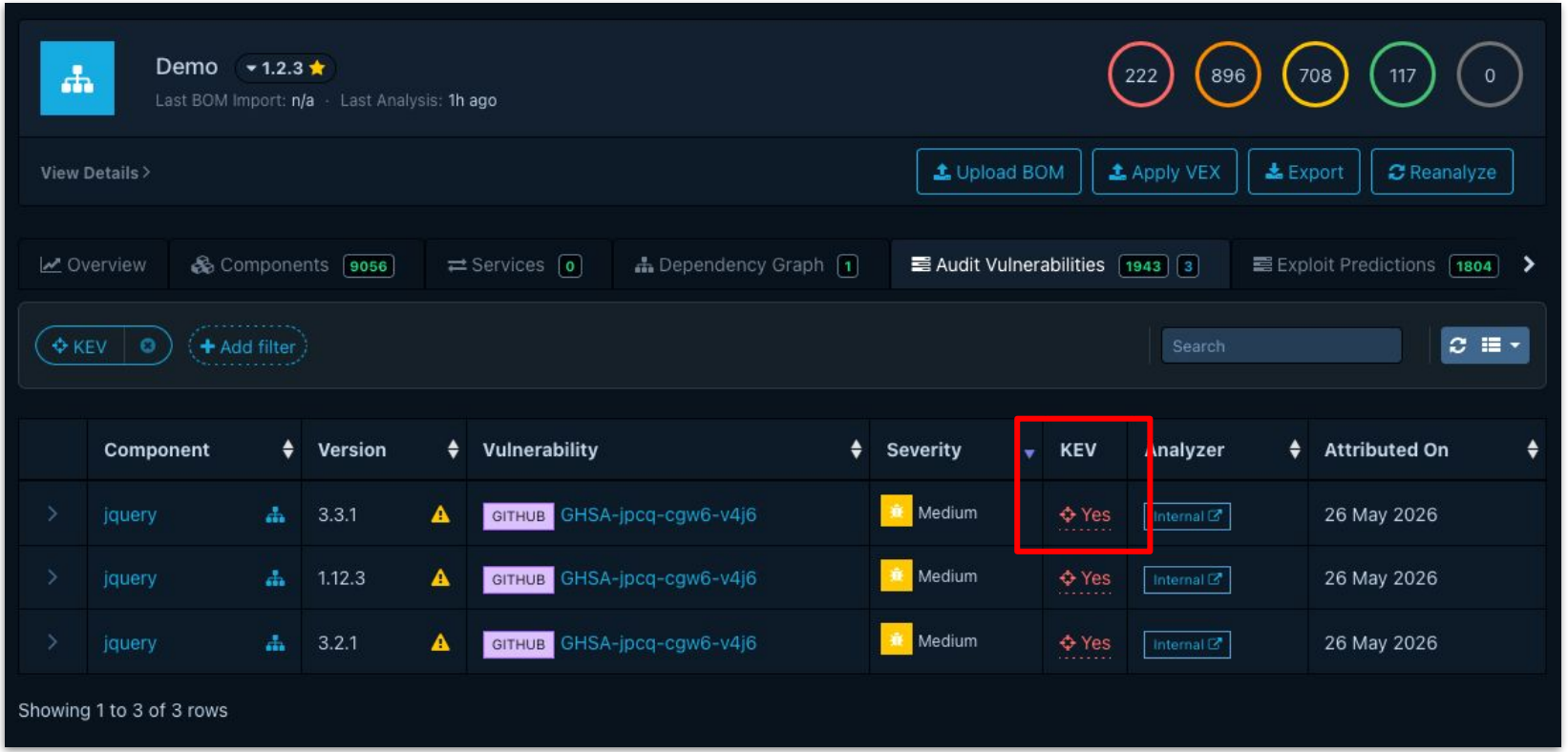
(Excluding unstable and custom versions)



(Excluding unstable and custom versions)

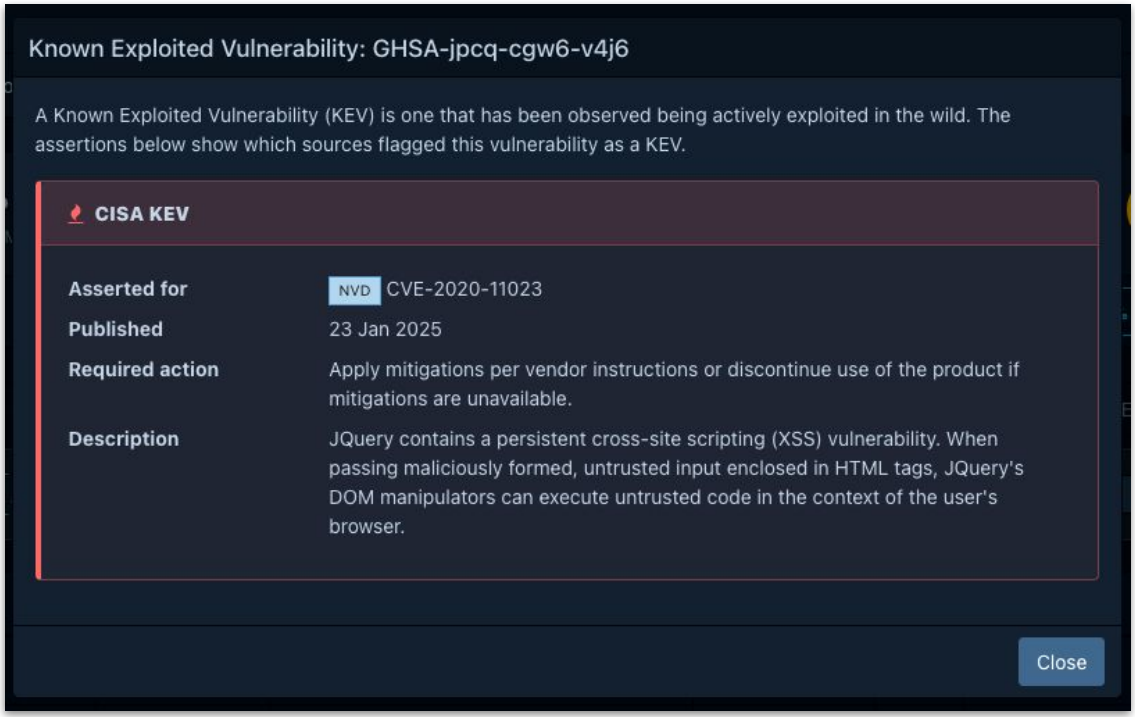
Noteworthy changes

5.1.0: KEV



Project vulnerabilities filtered by KEV status

5.1.0: KEV



KEV details

5.1.0: Query Timeouts

- Before 5.1.0: DB queries could run for unlimited time, clogging resources
- Max duration of DB queries limited to 60s by default
- REST API requests triggering the timeout get a HTTP 504 response
- Customizable, in case it causes problems

https://dependencytrack.github.io/docs/next/reference/configuration/properties/#dtdatasourcequery-timeout-ms

5.2.0: Service Accounts

- Before 5.2.0:
  - API keys only for teams, which hold 0..N users
  - No expiry, valid forever until explicitly deleted
  - Breaks non-repudiation: **who** used an API key?
- Service accounts are the way forward for non-human clients
  - API keys for teams will be removed in the next major version
- Identifiable by a fixed “`svc:`” name prefix
- Have permissions and can join teams like normal users
- API key expiry is mandatory
- Recommendation: migrate your team API keys to service accounts!

https://dependencytrack.github.io/docs/next/concepts/access-control/#service-accounts

5.2.0: Workload Identity Federation

- Enables service accounts to authenticate *without API key*
- Exchanges platform tokens for short-lived DT session tokens
- Works with GitHub Actions, k8s service accounts, SPIFFE, and more!
- Use instead of API keys; not having to manage credentials adds quality of life

https://dependencytrack.github.io/docs/next/guides/administration/configuring-workload-identity-federation/

5.2.0: Workload Identity Federation

```yaml
permissions:
  id-token: write
  contents: read
steps:
  - uses: DependencyTrack/gh-upload-sbom@v4
    with:
      server-hostname: 'example.com'
      workload-identity-provider: 'github-actions'
      service-account: 'ci'
      oidc-audience: 'https://dependency-track.example.com'
      project-name: 'Example Project'
      project-version: 'master'
      bom-filename: "/path/to/bom.xml"
      auto-create: true
```

Keyless authentication via GitHub Action
https://github.com/DependencyTrack/gh-upload-sbom#workload-identity-federation

5.2.0: Outbound Connection Policy

- Before 5.2.0:
  - Outbound connections must be limited at infrastructure level
  - Some subsystems have their own broad “allow external connections” config
- One config to cover all outbound connections
  - e.g. vuln data sources, analyzers, package repositories, notifications, …
  - Exceptions: DB, S3 file storage, LDAP server, OIDC IdP
- Ability to allowlist specific IPs, address ranges, hostnames

https://dependencytrack.github.io/docs/next/reference/configuration/properties/#dtoutboundallowed-destinations

5.2.0: Upload Size Limits

- Before 5.2.0: upload of documents with unlimited size
- Size of uploaded BOMs and VEXs limited to 100 MiB by default
- Intention: prevent large files from blowing up memory usage
- Configurable if needed, with separate limits for BOMs and VEXs

https://dependencytrack.github.io/docs/next/reference/configuration/properties/#dtbom-uploadmax-size-bytes

https://dependencytrack.github.io/docs/next/reference/configuration/properties/#dtvex-uploadmax-size-bytes

Upcoming 5.3 release

5.3: Focus on UI

- Migration from Vue.js 2.7 to 3.5, Bootstrap 4 to 5, Webpack to Vite etc.
- Removal of several dependencies to reduce footprint
- Introduction of Playwright e2e tests
- Various UI/UX improvements; better shown than listed :)

Q&A